TOOLLAW

GOAI 2026 · Track 1 Agent Infra · Accra Technical University · 2026-08-16

> **One sentence.** TOOLLAW compiles who may call which Skill or MCP tool, with which arguments, into a fail-closed allowlist. Policy Compiler writes the artifact; Red Team must lose in the Matrix room; Gateway Auditor proves the forbidden call did not execute and emits hashed evidence. Human ALLOW is L3-only.

Live. Product https://toollaww.vercel.app · MCP `/api/mcp` · sidecar `http://34.89.119.128:8787` · dashboard `http://34.89.119.128:13000` · Element `http://34.89.119.128:18088` · Higress `http://34.89.119.128:18001`

1. Scenario and value (25%)

Problem. OSS agent gateways typically ACL at **server** level. A Worker allowed to talk to an MCP server can still fire the wrong **tool** with the wrong **args**. Traces show the blast after it happens. Enterprises need enforcement: AppArmor / IAM for agent tools.

Users. Platform, SRE, and security teams running multi-agent fleets.

Value. Compiled tool-level law + red-team proof + hashed receipts. Replicable: swap fixture JSON; keep roles, Skills, and default BLOCK.

Not this idea. A logo stack; a LangGraph SRE crew; official demo 4 incident chat; a trading product.

2. Solution

Policy Compiler writes an allowlist Skill; Red Team attacks with a fixture pack; Auditor matches policy hash to the attempt; Human L3 is required on high-risk and cannot be the attacker. Halt / redeem / peer-env events are an **attack pack**, not the pitch. Moat: *Traces show what happened. TOOLLAW decides what is allowed to happen.*

3. Multi-agent closed loop (25%)

Baseline: AgentTeams Manager–Workers in a Matrix room. Humans are first-class members (L3 on high-risk).

Step	Who	AgentTeams mapping
Task input	Red Team	Worker posts fixture JSON as a `ToolLaw` attempt
Decomposition	Manager + Policy Compiler	TeamHarness assigns compile vs attack vs audit
Context passing	Shared `ToolLaw` object	Files / artifacts, not a 20k-token dump
Tool calling	Skills + MCP-shaped catalog	Gateway holds secrets
Result verification	Auditor	`executed: false` on BLOCK; ALLOW on health read
Evidence	Auditor	policyHash + sha256 receipt
Approval / rollback	Human L3	No ticket → BLOCK (prevent, not undo)
Experience capture	Auditor	Writes reusable `toollaw.deny-unhalt`

Exception branches. Unknown tool → BLOCK. Peer path in env args → BLOCK. Unsettled redeem → BLOCK. Red Team calling approve → BLOCK. Compiler error → `BLOCKED`, do not load stale policy.

4. Agent identity list (Appendix A)

ID	Role	AgentTeams	May	Must not
mgr	Manager	Manager	Create Team, track state	Fire tools
pol	Policy Compiler	Leader or Worker	Compile YAML → allowlist	Execute risky tools
red	Red Team	Worker	Attack with forbidden Skills	Self-approve
aud	Gateway Auditor	Worker	Match traces, evidence	Weaken allowlist
hum	Human	Matrix Human	ALLOW / DENY	Be optional on high-risk

State machine: `OPEN → COMPILING → ATTACKING → BLOCKED | AWAITING_APPROVAL → VERIFYING → CLOSED`.

5. Skills (mandatory, 25%)

Skill	Purpose	Mutate	Approval
toollaw.compile	Hash allowlist artifact	artifact	no
toollaw.enforce	Deterministic gate	no	n/a
toollaw.redteam	Submit attack fixture	attempts only	must fail closed
toollaw.evidence	Receipt sha256	evidence	no
toollaw.approve	Human L3 ticket	ticket	human-only
toollaw.health	Read fixture	no	no
toollaw.deny-unhalt	Capture after BLOCK	no	n/a

Attack surface (fixtures, not product Skills): `fixture.unhalt`, `fixture.redeem`, `fixture.env.patch`.

6. Engineering / audit (20%) and OSS (5%)

Typed JSON Schema for the `ToolLaw` object and compiled policy. Default fail-closed. Evidence zip for judges. Apache-2.0. No secrets in git. Fixtures are synthetic.

7. Demo loop (3 Sep, same loop 22 Sep)

Red Team fires high-risk Skill → BLOCK + receipt → Human ALLOW on `toollaw.health` → peer-fleet env patch BLOCK → Auditor zip. Kill beat: Red Team cannot stamp its own ticket.

8. Honest limits

Prelim is completeness and scenario. Semi requires a runnable AgentTeams fail-closed loop. Higress OSS vs Enterprise tool-level ACL is treated as a gap we close with Skills.